

Cirque Corporation

Incident Response Procedure (US Localized)

Document ID: IS-CIRQ-PR-020-US

Category: IT Security Related

Division: Procedure

Type: Localized (US)

Version: 1.0

Effective Date: 2025-07-01

Review Date: 2026-07-01

Approved By: IT Manager, US General Manager

Generated: March 02, 2026

1. Purpose

The purpose of this procedure is to provide localized guidelines for managing information security incidents affecting Cirque's operations, assets, and information within the United States. It supplements the IS-CIRQ-PR-020-G: Incident Response Procedure (Global Core) by detailing US-specific legal, regulatory, and reporting requirements, as well as local contacts and resources for incident response.

****2. Scope****

2. Scope

This procedure applies to all Cirque personnel, information assets, information systems, applications, and networks located within or primarily serving the United States. It covers all suspected or confirmed information security incidents impacting US operations or data related to US citizens or residents.

****3. Responsibilities (US-Specific)****

3. Responsibilities (US-Specific)

- **US General Manager:** Responsible for awareness of incidents affecting US operations and ensuring local compliance. May act as a primary point of contact for US-specific legal or regulatory inquiries.
- **US IT Lead/Local Administrator:** Primary local contact for incident detection, initial containment, and evidence collection within US operations. Works under the direction of the Global IT Manager.
- **US Legal Counsel (or designated external counsel):** Provides specific legal guidance on US federal and state data breach notification laws (e.g., HIPAA, CCPA, New York SHIELD Act, state-specific breach notification laws) and other relevant regulations.
- **US Human Resources:** Involved in incidents affecting US employees or requiring internal investigations related to personnel.

4. US-Specific Incident Response Guidelines

4. US-Specific Incident Response Guidelines

This procedure follows the six phases outlined in IS-CIRQ-PR-020-G: Incident Response Procedure (Global Core). The following sections detail US-specific considerations for each phase:

4.1. Phase 1: Preparation (US Localized)

- Regulatory Awareness:** US IT Lead and US General Manager must stay updated on relevant US federal and state data breach notification laws, industry-specific regulations (e.g., if handling healthcare or financial data), and privacy laws (e.g., CCPA, state privacy laws).

b). **Local Contacts:** Maintain an up-to-date list of US-specific contacts:

* Local law enforcement (FBI field office, local police cybercrime unit).

* Relevant regulatory bodies (e.g., FTC, state Attorneys General, specific industry regulators).

* Designated external US Legal Counsel for breach response.

* Local IT support vendors/partners, if applicable.

c). **Incident Response Plan Exercise:** Include US-specific scenarios in tabletop exercises (e.g., a breach affecting California residents, a system outage in the US office).

****4.2. Phase 2: Detection and Analysis (US Localized)****

a). **Local Reporting Channels:** While global channels remain primary, US personnel should also be aware of any local IT or management contacts for immediate reporting during US business hours.

b). **Initial Data Point:** For incidents originating or detected within the US, the US IT Lead will be a key resource for initial data collection from local systems, network devices, and user devices.

****4.3. Phase 3: Containment (US Localized)****

a). **Local Coordination:** Containment efforts within US facilities (e.g., disconnecting specific US-based servers, isolating US network segments) will be coordinated by the US IT Lead under the direction of the Global IT Manager.

****4.4. Phase 4: Eradication (US Localized)****

a. **Local Remediation:** Remediation steps on US-based systems, such as patching US servers or reimaging US workstations, will be executed by the US IT Lead or designated local IT personnel.

****4.5. Phase 5: Recovery (US Localized)****

a. **US System Restoration:** The recovery of US-specific systems and data will involve US IT personnel to ensure local verification and operational readiness.

****4.6. Phase 6: Post-Incident Activity (Lessons Learned - US Localized)****

a. **US Legal Review:** All incident reports potentially involving personal data of US residents must undergo review by US Legal Counsel to determine specific notification obligations under relevant federal and state laws.

b. **Regulatory Reporting:** The IT Manager, in consultation with US Legal Counsel and US General Manager, is responsible for fulfilling any mandatory data breach notification requirements to affected individuals, state Attorneys General, or other relevant US regulatory bodies within specified timelines.

c. **Lessons Learned Integration:** US-specific findings and recommendations from post-incident reviews will be incorporated into this localized procedure and communicated to global IT.

****5. US-Specific Communication and External Reporting****

5. US-Specific Communication and External Reporting

a. **Notification to Affected Individuals:** In the event of a data

breach involving personal information of US residents, notifications shall be made in accordance with the specific state laws where the individuals reside. This includes content, timing, and method of notification.

b). **Regulatory Notifications:** Specific regulatory bodies in the US (e.g., Department of Health and Human Services for HIPAA, state Attorneys General, specific industry regulators) may require direct notification. This is to be handled by the IT Manager, US General Manager, and US Legal Counsel.

c). **Law Enforcement:** For criminal incidents, collaboration with US federal (e.g., FBI Cyber Division) or local law enforcement will be managed by the IT Manager and US Legal Counsel.

****6. Review and Update****

6. Review and Update

This localized procedure will be reviewed at least annually, or sooner if there are significant changes to Cirquel's US operations, new US federal or state privacy/breach notification laws, or lessons learned from incidents impacting US entities.

****7. Related Documents****

7. Related Documents

- IS-CIRQ-P-014-G: Information Security Incident Management Policy
- IS-CIRQ-PR-020-G: Incident Response Procedure (Global Core)
- IS-CIRQ-P-001-G: Information Security Policy
- State-specific data breach notification laws (external reference, to be monitored by Legal)

- Relevant US federal regulations (external reference)